Checkpoint Minggu 9

Skenario 10, IoT Protocol Guardian: melindungi backend sistem sprinkler kandang sapi.

Thevan Erlangga (Lead, Purple Team) | Muhamad Akhdan Ramadhan (Red Team) | Fachri Abyasa Tarid (Blue Team).

Lab terisolasi 192.168.12.0/24: penyerang .100, target .5, monitoring .200.

Sembilan kontrol hardening terpasang dan teruji, tiga skenario serangan sudah dieksekusi.

1 Konteks proyek IoT: SmartCow

Sistem sprinkler kandang sapi dengan enam sensor DS18B20 dan empat DHT22 di dua ESP32.

ESP kanan menggabungkan data, lalu menulis telemetri ke Firebase Realtime Database lewat HTTPS REST. Dashboard di Firebase Hosting dipakai peternak untuk memantau suhu dan kelembapan, serta mengatur ambang penyalaan semprotan.

Relay GPIO23 menjaga solenoid 220V. Semprotan menyala saat rata-rata suhu menyentuh ambang, dengan hysteresis, durasi maksimum, dan cooldown.

Celah yang paling jelas dibaca: Database Secret tertanam di dalam sketch firmware, TLS memakai setInsecure, dan ESP-NOW berjalan tanpa enkripsi.

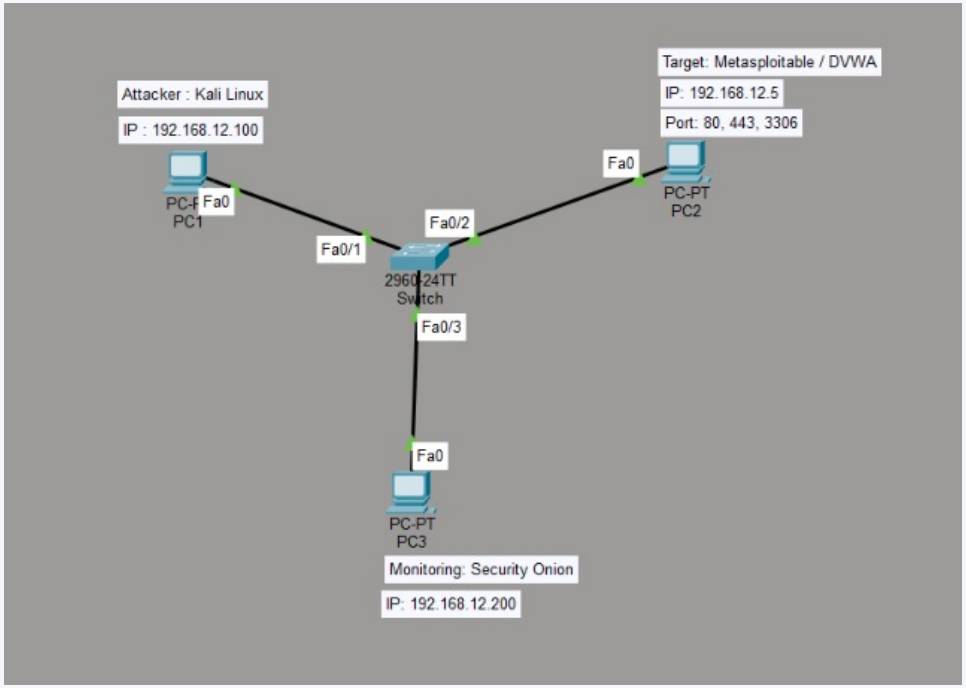
2 Deklarasi tech stack dan replikanya

Komponen	Proyek IoT asli	Replika Target Node
Backend	Firebase terkelola Google	Arch Linux, service systemd
Data	Firebase Realtime Database	Penyimpanan JSON dengan endpoint REST bergaya RTDB
Protokol	HTTPS REST dengan Database Secret	HTTP REST dengan token, plus broker MQTT
Dashboard	Firebase Hosting, HTML dan JavaScript	Nginx 1.18.0 dengan proxy /api
Auth	Firebase Authentication dan rules RTDB	Token bearer, kredensial broker, ACL topik

Komponen	Proyek IoT asli	Replika Target Node
Sensor	Enam DS18B20 dan empat DHT22	Simulator Python, data dummy tiap 2 detik

Lab tidak punya akses internet, jadi Firebase Emulator tidak bisa dipasang. Replika memakai Python 3.9 standar dari Arch. Pemetaan lengkap ada di tech_stack_declaration.md.

3 Arsitektur simulasi



Attacker 192.168.12.100 menuju Target 192.168.12.5, dipantau Security Onion 192.168.12.200. Semua node terisolasi di Host-Only, tidak ada rute ke luar segmen.

4 Progres hardening: sembilan kontrol, tiga kategori

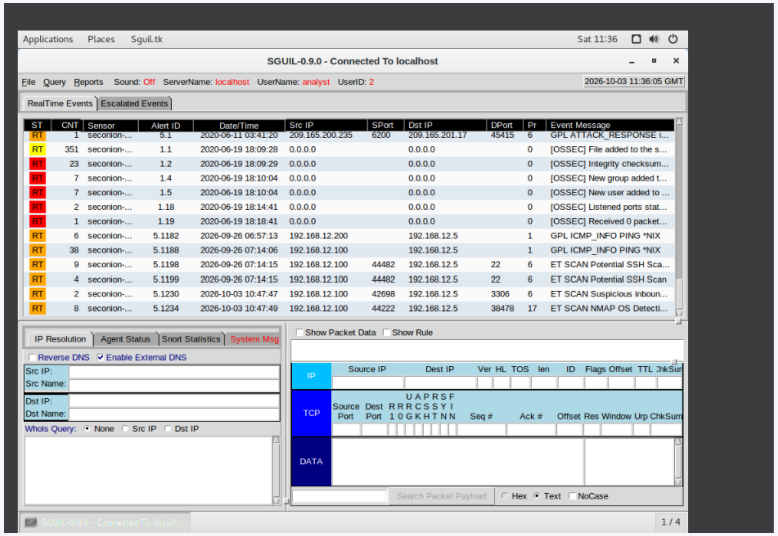
Kategori	Kontrol	Status
A. Access and Authentication	A1 tolak login root, A2 login kunci tanpa password, A3 batas percobaan dan laju koneksi	3 Done
B. Service and Attack Surface	B1 firewall whitelist persisten, B2 API hanya di loopback, B3 sembunyikan versi Nginx	3 Done
C. Data and Application	C1 validasi input dan ACL topik MQTT, C2 kredensial ketat dan rotasi, C3 logging dan backup	3 Done

Semua kontrol punya bukti before dan after berupa tangkapan layar terminal asli.

Baseline traffic: simulator menulis telemetri dummy tiap dua detik, sensor Onion menangkapnya sebagai trafik normal.

Bukti lengkap ada di docs/blueteam/hardening_checklist.md.

5 Live demo dan attack plan Fase 2



Demo: ping dan scan dari penyerang, lalu baris event baru muncul di Security Onion.

Tiga skenario, tiga kategori: RT-01 reconnaissance dengan nmap, RT-02 percobaan login SSH berulang, RT-03 publish MQTT dan suntik data REST.

Sebelum hardening, login penyerang berhasil, publish ke topik perintah diterima, dan data palsu tersimpan di target. Sesudah hardening, semuanya ditolak.

6 Kendala dan pembelajaran

Security Onion tidak bisa diakses dari host. Antarmuka managementnya tidak menjawab ARP dan VM itu tidak punya SSH server, jadi bukti alert diambil manual dari layar Onion.

Lab tanpa internet. Fail2ban, hydra, sshpass, dan mosquitto tidak bisa dipasang, sehingga skrip klien sendiri dipakai untuk pengujian.

Aturan firewall hilang setelah reboot di Fase 1. Sekarang aturan disimpan ke /etc/iptables/iptables.rules dan dimuat oleh service, sehingga tidak hilang lagi.

Rekomendasi yang sudah siap disruptive ke proyek asli: rotasi Database Secret, hapus setInsecure, dan siapkan broker MQTT dengan autentikasi.